

Universidad Tecnológica Nacional

Regional Venado Tuerto

SEGURIDAD EN LOS SISTEMAS OPERATIVOS

Amenazas, mecanismos de protección y buenas prácticas

Materia: Arquitectura y Sistemas Operativos

Comisión: 11

Integrantes: Franco Kaddour — Gonzalo Isaias

Profesor/a: Carlos Andrés Odiard

Fecha de entrega: 25/06/2026

ÍNDICE

1. Introducción	3
2. Marco Teórico	4
3. Caso Práctico	8
4. Metodología Utilizada	10
5. Resultados Obtenidos	11
6. Conclusiones	12
7. Bibliografía	13
8. Anexos	14

1. INTRODUCCIÓN

El sistema operativo es el núcleo sobre el que corre todo el software de una computadora. Cuando es vulnerado, todo lo que depende de él queda expuesto: datos, aplicaciones y usuarios.

La seguridad informática dejó de ser una preocupación exclusiva de grandes empresas o gobiernos. En la actualidad, cualquier dispositivo conectado a internet representa un blanco potencial. Los ataques son automatizados, globales y cada vez más accesibles para quien quiera ejecutarlos.

Este trabajo se propone los siguientes objetivos:

- Analizar las principales amenazas que enfrentan los sistemas operativos modernos.
- Comprender los mecanismos de defensa disponibles en Linux y Windows.
- Conocer las buenas prácticas que todo administrador y usuario debe aplicar.
- Demostrar, de forma práctica, cómo se configuran estas protecciones en un sistema real.

El tema fue elegido por su relevancia directa en la formación como técnicos en programación: cualquier sistema que se desarrolle corre sobre un sistema operativo, y comprender sus mecanismos de seguridad es una competencia transversal a todos los perfiles del área tecnológica.

2. MARCO TEÓRICO

2.1 ¿Qué es la seguridad en sistemas operativos?

La seguridad en sistemas operativos es el conjunto de mecanismos, políticas y prácticas diseñados para proteger los recursos del sistema frente a accesos no autorizados, modificaciones indebidas o destrucción de información.

El sistema operativo actúa como la primera línea de defensa: gestiona quién puede acceder a cada recurso, qué operaciones puede realizar, y registra todo lo que ocurre. Si esta capa es comprometida, todo lo que corre sobre ella queda expuesto.

2.2 La Tríada CIA

Todo sistema seguro debe garantizar tres propiedades fundamentales, conocidas como la Tríada CIA:

Propiedad	Descripción	Ejemplo práctico
Confidencialidad	Solo usuarios autorizados acceden a la información	Permisos de archivo, cifrado de disco
Integridad	La información no puede ser alterada sin autorización	Hashes, control de permisos de escritura
Disponibilidad	El sistema funciona cuando se lo necesita	Backups, protección contra ataques DoS

Estas tres propiedades no son independientes: un ataque de ransomware viola simultáneamente la disponibilidad (no se puede acceder a los archivos) y potencialmente la confidencialidad (el atacante puede exfiltrar los datos antes de cifrarlos).

2.3 Principio de mínimo privilegio

Cada usuario o proceso debe contar con solo los permisos necesarios para cumplir su función, y no más. Este principio es fundamental porque limita el daño potencial cuando una cuenta o proceso es comprometido: si un atacante accede a una cuenta con permisos bajos, no podrá afectar al resto del sistema fácilmente.

2.4 Caso de estudio: WannaCry (2017)

En mayo de 2017, el ransomware WannaCry infectó más de 200.000 sistemas en 150 países en menos de 24 horas. El ataque paralizó hospitales del Reino Unido, empresas de telecomunicaciones, bancos y organismos gubernamentales. El costo económico global estimado superó los 4.000 millones de dólares.

El ataque siguió una secuencia completamente automatizada:

Etapas	Acción
1. Escaneo	Buscaba equipos con el puerto 445 abierto (protocolo SMB de Windows)
2. Explotación	Utilizaba EternalBlue (CVE-2017-0144), una vulnerabilidad crítica de Windows aún sin parchar
3. Instalación	Instalaba un backdoor con control total sobre el sistema comprometido
4. Cifrado	Cifraba todos los archivos del usuario con RSA-2048 y los renombraba con extensión .WNCRY
5. Extorsión	Mostraba un mensaje exigiendo 300-600 USD en Bitcoin para recuperar los datos
6. Propagación	Se replicaba automáticamente hacia otros equipos de la misma red (comportamiento tipo gusano)

La lección más importante: Microsoft había publicado el parche de seguridad correspondiente (MS17-010) dos meses antes del ataque. Los sistemas infectados simplemente no estaban actualizados. WannaCry no explotó una vulnerabilidad desconocida ni requirió técnicas avanzadas: explotó la negligencia. Este caso demuestra que muchos de los incidentes más graves de la historia no ocurrieron por falta de tecnología disponible, sino por falta de aplicación de medidas básicas.

2.5 Principales amenazas

Por tipo de ataque

Amenaza	Descripción
Malware	Software malicioso diseñado para dañar, robar o espiar (virus, troyanos, spyware)
Ransomware	Variante de malware que cifra los datos del sistema y exige un pago para recuperarlos
Phishing	Correos electrónicos o páginas web falsas creadas para robar credenciales

Amenaza	Descripción
Fuerza bruta	Intentos automatizados y masivos de adivinar contraseñas hasta dar con la correcta
Rootkit	Malware que opera a nivel kernel del sistema, haciéndose invisible para el antivirus
Escalada de privilegios	Técnica por la cual un atacante con acceso limitado logra obtener control total del sistema

Por capa del sistema atacada

Capa	Ejemplos de ataques
Red	Escaneo de puertos, fuerza bruta SSH, denegación de servicio (DoS)
Usuario	Phishing, ingeniería social, malware ejecutado por el usuario
Aplicación	Exploits de software, inyección de código, desbordamiento de buffer
Kernel	Rootkits, vulnerabilidades del núcleo del sistema operativo

2.6 Seguridad en Linux

Filosofía de seguridad

Linux fue diseñado como un sistema multiusuario con separación estricta de privilegios. El principio de mínimo privilegio no es una capa agregada sobre el sistema: es parte de su diseño original. Esto explica por qué Linux tiene, de base, una superficie de ataque menor que otros sistemas.

Modelo de permisos Unix

Linux asigna permisos a tres niveles: propietario, grupo y otros. Cada nivel puede tener tres tipos de acceso: lectura (r), escritura (w) y ejecución (x).

Notación numérica (la más utilizada en la práctica):

Número	Permisos	Uso típico
777	rwXrwxrwx	Todos pueden hacer todo — INSEGURO
755	rwXr-Xr-X	Scripts y binarios ejecutables
644	rw-r--r--	Archivos de configuración
600	rw-----	Archivos sensibles (claves SSH, contraseñas)

```
ls -la # Ver permisos de todos los archivos del directorio
chmod 600 archivo_sensible.txt # Solo el propietario puede leer y escribir
chmod 755 script.sh # Ejecutable por todos, editable solo por el dueño
chown usuario:grupo archivo.txt # Cambiar propietario y grupo del archivo
```

root vs. sudo

root es el superusuario de Linux: tiene acceso irrestricto a todo el sistema. Trabajar directamente como root es una mala práctica porque cualquier error, o cualquier malware ejecutado en esa sesión, tiene consecuencias sobre todo el sistema. sudo es la alternativa segura: permite ejecutar comandos con privilegios de forma puntual, controlada y auditada. Cada comando ejecutado con sudo queda registrado en /var/log/auth.log.

Firewall con ufw y protección con fail2ban

```
sudo ufw enable # Activar el firewall
sudo ufw default deny incoming # Rechazar todo el trafico entrante por defecto
sudo ufw default allow outgoing # Permitir todo el trafico saliente
sudo ufw allow 22 # Permitir conexiones SSH
sudo ufw deny 23 # Bloquear Telnet (protocolo sin cifrado)
sudo ufw status verbose # Ver el estado y las reglas activas
```

La regla más importante es default deny incoming: si no se permite explícitamente un tipo de tráfico, el sistema lo rechaza. fail2ban complementa esto monitoreando los registros y bloqueando automáticamente las IP con múltiples intentos de login fallidos (lectura de /var/log/auth.log y regla automática en iptables).

2.7 Seguridad en Windows

UAC (Control de Cuentas de Usuario): solicita confirmación cada vez que una aplicación intenta realizar cambios que requieren privilegios administrativos. Impide que el malware actúe en silencio con permisos totales. **Windows Defender:** suite integrada (antivirus, firewall, SmartScreen, Exploit Guard). **BitLocker:** cifrado de disco completo. **Visor de Eventos:** registra la actividad; los IDs 4624 (login exitoso), 4625 (login fallido), 4720 (nueva cuenta) y 4732 (alta en grupo con privilegios) son clave. **Windows Update:** distribuye los parches que habrían evitado WannaCry.

```
Get-MpComputerStatus | Select-Object AntivirusEnabled, RealTimeProtectionEnabled
Get-MpThreatDetection | Select-Object ThreatID, ActionSuccess, InitialDetectionTime
```

2.8 Comparativa: Linux vs. Windows

Aspecto	Linux	Windows
Malware existente	Cantidad reducida	Enorme volumen de amenazas activas
Modelo de privilegios	root/sudo — integrado desde el diseño	UAC — incorporado desde Vista (2007)
Firewall	iptables / ufw — integrado en el kernel	Windows Defender Firewall
Actualizaciones	Gestionadas por el administrador	Automatizadas (Patch Tuesday)

Aspecto	Linux	Windows
Código fuente	Abierto — auditable públicamente	Cerrado — revisión limitada
Uso en servidores	Dominante (>70% del mercado)	Relevante en entornos corporativos
Curva de aprendizaje	Mayor — requiere terminal	Menor — interfaz gráfica completa

Ninguno de los dos sistemas es inherentemente más seguro en términos absolutos. La seguridad real depende de la configuración, el mantenimiento y las prácticas del administrador.

2.9 Buenas prácticas

Contraseña	Tiempo estimado para crackear
123456	Instantáneo
Contraseña1	Menos de un segundo
Xk#9mP\$vL2qN	Cientos de años
caballo-bateria-grapa-luz (passphrase)	Cientos de años — y fácil de recordar

Se recomienda un gestor de contraseñas (Bitwarden, KeePassXC), autenticación multifactor (MFA) —Microsoft reportó que bloquea el 99,9 % de los ataques automatizados— y la regla de backups 3-2-1: tres copias, en dos soportes distintos, una de ellas fuera del sitio. Aplicar parches dentro de los 30 días de su publicación es el estándar de la industria.

3. CASO PRÁCTICO

Se configuró un entorno con dos sistemas para demostrar los mecanismos de seguridad de forma práctica y reproducible: Ubuntu (Linux) para permisos, firewall y monitoreo; y Windows 10/11 para herramientas nativas y auditoría de eventos.

3.1 En Linux — Gestión de permisos y protección del sistema

Objetivo: demostrar cómo los permisos Unix protegen archivos sensibles y cómo se monitorea la actividad del sistema.

```
# 1. Crear un archivo con informacion sensible
echo "Datos sensibles del sistema" > archivo_sensible.txt

# 2. Ver los permisos actuales (por defecto legible por todos)
ls -la archivo_sensible.txt          # -rw-r--r-- ...

# 3. Aplicar permisos restrictivos
chmod 600 archivo_sensible.txt
ls -la archivo_sensible.txt          # -rw----- (solo el propietario)

# 4. Configurar el firewall
sudo ufw enable
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22
sudo ufw status verbose

# 5. Verificar intentos de acceso no autorizado
sudo grep "Failed password" /var/log/auth.log | tail -10

# 6. Verificar puertos abiertos (servicios expuestos)
sudo ss -tulpn

# 7. Buscar binarios SUID (posibles vectores de escalada)
find /usr/bin -perm -4000 -type f 2>/dev/null
```

3.2 En Windows — Auditoría y herramientas nativas

Objetivo: demostrar el uso del Visor de Eventos, Windows Defender y la política de contraseñas desde PowerShell.

```
# 1. Estado completo de Windows Defender
Get-MpComputerStatus | Select-Object AntivirusEnabled, RealTimeProtectionEnabled,
    AntivirusSignatureLastUpdated

# 2. Amenazas detectadas recientemente
Get-MpThreatDetection | Select-Object ThreatID, ActionSuccess, InitialDetectionTime |
    Format-Table -AutoSize

# 3. Estado del Firewall de Windows
Get-NetFirewallProfile | Select-Object Name, Enabled | Format-Table

# 4. Ultimos 10 intentos de login fallidos (ID 4625)
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} -MaxEvents 10 |
    Select-Object TimeCreated, Message | Format-Table -AutoSize

# 5. Cuentas de usuario locales
Get-LocalUser | Select-Object Name, Enabled, LastLogon | Format-Table

# 6. Politica de contraseñas del sistema
net accounts

# 7. Puertos en escucha
netstat -an | findstr "LISTENING"
```

4. METODOLOGÍA UTILIZADA

El desarrollo del trabajo siguió las siguientes etapas:

Investigación y marco teórico: se consultaron fuentes académicas (Stallings, Tanenbaum), documentación oficial (NIST, Microsoft Learn, Linux Documentation Project) y reportes técnicos sobre WannaCry (Kaspersky Lab, NCSC UK). Se priorizaron fuentes primarias y actualizadas.

Diseño de la demostración práctica: se definieron los casos de uso a demostrar en cada sistema operativo, seleccionando herramientas nativas sin instalaciones complejas. El criterio fue la reproducibilidad: cualquier usuario con Ubuntu o Windows 10/11 puede ejecutar los mismos comandos y obtener los mismos resultados.

Entorno de trabajo:

- Linux: el script `demo_linux.sh` está diseñado para Ubuntu 22.04 LTS (utiliza `sudo`, `ufw` y `apt`) y es ejecutable en VirtualBox, WSL2 o hardware nativo. La captura del Anexo A se obtuvo en un entorno Linux disponible.
- Windows: Windows 10/11 con PowerShell 5.1 o superior.

División de tareas:

- Franco Kaddour: marco teórico (Tríada CIA, WannaCry, amenazas), implementación y documentación de la parte Linux, estructura general del documento.
- Gonzalo Isaías: implementación y documentación de la parte Windows, comparativa Linux vs. Windows, buenas prácticas.

Herramientas utilizadas: edición en Visual Studio Code; presentación en Canva; scripts diseñados para Ubuntu 22.04 LTS (Linux) y Windows 10/11.

5. RESULTADOS OBTENIDOS

La ejecución de la demostración práctica permitió verificar el correcto funcionamiento de todos los mecanismos presentados.

En Linux

- `chmod 600` restringió el acceso a un archivo de modo que solo el propietario puede leerlo o modificarlo. Un intento desde otro usuario devuelve `Permission denied`.
- El firewall `ufw` con `default deny incoming` bloqueó el tráfico no autorizado; solo el puerto 22 (SSH) quedó habilitado explícitamente.
- Los logs de `/var/log/auth.log` permitieron identificar intentos de acceso fallidos, validando el mecanismo de auditoría.
- La búsqueda de binarios SUID devolvió la lista de archivos que podrían ser vectores de escalada si estuvieran mal configurados.

En Windows

- Windows Defender reportó estado activo con protección en tiempo real habilitada y firmas actualizadas.
- El Visor de Eventos (ID 4625) permitió listar intentos de inicio de sesión fallidos.
- La política de contraseñas verificada con `net accounts` mostró longitud mínima y vencimiento configurados.

- El Firewall de Windows confirmó los perfiles de dominio, privado y público activos.

Dificultades encontradas

- Algunos comandos de PowerShell de eventos de seguridad requieren ejecutar la terminal como Administrador. Se documentó este requisito en el script.
- En entornos virtualizados, ciertos eventos de auditoría no están habilitados por defecto y requieren activación manual en la Política de seguridad local.

6. CONCLUSIONES

La seguridad en sistemas operativos no es un estado que se alcanza: es un proceso continuo de configuración, monitoreo y actualización.

El caso WannaCry es el ejemplo más claro de esto: el ataque más devastador de 2017 se habría evitado con una actualización que llevaba dos meses disponible. La tecnología existía; la práctica, no.

La mayoría de los incidentes de seguridad no responden a ataques extremadamente sofisticados, sino a descuidos prevenibles: contraseñas débiles, sistemas desactualizados, servicios expuestos sin necesidad, permisos más amplios de lo necesario.

Las herramientas para proteger un sistema —tanto en Linux como en Windows— están disponibles, son en su mayoría gratuitas y muchas vienen integradas de fábrica. La diferencia entre un sistema seguro y uno vulnerable no es el presupuesto: es el conocimiento y la disciplina para aplicarlo.

"La seguridad no es un producto, es un proceso." — Bruce Schneier

Comprender estos conceptos no es solo un requisito académico: es una competencia fundamental para cualquier persona que trabaje con tecnología, ya sea como administrador de sistemas, desarrollador o usuario avanzado.

7. BIBLIOGRAFÍA

Listado de fuentes consultadas (formato APA):

Libros y artículos

- 1 Shotts, W. (2019). The Linux Command Line: A Complete Introduction (2.^a ed.). No Starch Press.
- 2 Stallings, W. (2018). Operating Systems: Internals and Design Principles (9.^a ed.). Pearson Education.
- 3 Tanenbaum, A. S. & Bos, H. (2014). Modern Operating Systems (4.^a ed.). Pearson Education.
- 4 Schneier, B. (2000). Secrets and Lies: Digital Security in a Networked World. Wiley.
- 5 Anderson, R. (2020). Security Engineering: A Guide to Building Dependable Distributed Systems (3.^a ed.). Wiley.

Documentación oficial

- 1 NIST (2024). Cybersecurity Framework. National Institute of Standards and Technology. <https://www.nist.gov/cyberframework> (consultado en junio de 2026).
- 2 Microsoft Learn. Windows Security documentation. <https://learn.microsoft.com/en-us/windows/security> (consultado en junio de 2026).
- 3 Microsoft Security Response Center. Boletín de seguridad MS17-010. <https://learn.microsoft.com/en-us/security-updates/>
- 4 Linux man pages: chmod(1), chown(1), sudo(8), ufw(8), iptables(8). <https://man7.org/linux/man-pages/>
- 5 Ubuntu Documentation. AppArmor. <https://ubuntu.com/server/docs/security-apparmor>
- 6 Fail2ban Documentation. https://www.fail2ban.org/wiki/index.php/Main_Page
- 7 INCIBE. Guías de ciberseguridad para usuarios y empresas. <https://www.incibe.es>

Reportes técnicos y caso WannaCry

- 1 MITRE. CVE-2017-0144: EternalBlue vulnerability. <https://cve.mitre.org>
- 2 National Cyber Security Centre UK (2017). WannaCry ransomware attack. <https://www.ncsc.gov.uk>
- 3 Kaspersky Lab (2017). WannaCry ransomware used in widespread attacks all over the world. <https://securelist.com>

8. ANEXOS

Anexo A — Ejecución del script de demostración Linux

Captura de la terminal ejecutando la demostración de seguridad en Linux. Se observa la diferencia de permisos antes y después de aplicar chmod 600 (de -rw-r--r-- a -rw-----), la identidad del usuario (whoami, id), las primeras líneas de /etc/passwd y la búsqueda de archivos con bit SUID.

```
loading...
Welcome to 75/Linux (x86_64)

Use 'vlogin username' to connect to your account.
You can create a new account at https://vlogin.org/signup.
Use 'export file filename' to export a file to your computer.
Imported files are written to the home directory.

localhost:~# echo "=== 1. PERMISOS ==="; echo "data" > f.txt; ls -l f.txt; chmod
600 f.txt; echo "tras chmod 600:"; ls -l f.txt
=== 1. PERMISOS ===
-rw-r--r-- 1 root root 5 Jun 25 09:49 f.txt
tras chmod 600:
-rw----- 1 root root 5 Jun 25 09:49 f.txt
localhost:~# echo "=== 2. USUARIOS ==="; whoami; id; head -5 /etc/passwd
=== 2. USUARIOS ===
root
uid=0(root) gid=0(root)
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/bin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lpadmin:x:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
localhost:~# echo "=== 3. SUID ==="; find /bin /usr/bin -perm -4000 -type f 2>/dev/null; echo "=== FIN ==="
=== 3. SUID ===
=== FIN ===
localhost:~#
```

Figura A.1 — Ejecución de la demostración de seguridad en un entorno Linux.

Anexo B — Ejecución del script de demostración Windows

Captura de PowerShell (ejecutado como Administrador) corriendo demo_windows.ps1. Se observa el estado de Windows Defender (antivirus y protección en tiempo real activos), el estado del firewall en los tres perfiles, un intento de inicio de sesión fallido registrado por el Visor de Eventos (ID

4625), las cuentas de usuario locales, la política de contraseñas (net accounts) y los puertos en escucha.

[illegible]

Figura B.1 — Ejecución de `demo_windows.ps1` en Windows 11.

Anexo C — Código fuente de las demostraciones

Los scripts completos se incluyen en la carpeta codigo/ entregada junto a este informe:

- `codigo/demo_linux.sh` — demostración de seguridad en Linux (Bash).
- `codigo/demo_windows.ps1` — demostración de seguridad en Windows (PowerShell).